React 原型角色权限分视图实施方案

> 版本: v1.0
>
> 日期: 2026-04-11
>
> 依据: PRD v1.7（二、用户角色与权限矩阵）/ RBAC_MATRIX v1.0
>
> 范围: React 原型（ `frontend/` ），mock 角色切换，不含真实后端鉴权

一、目标

在 React 原型中实现**页面级 / 功能级 / 字段级**三层权限控制，覆盖 5 个内部角色，通过 Profile 页角色切换器演示不同角色体验。排除二房东（ `sub_landlord` ）。

二、角色定义

角色标识	中文名	定位	Mock 用户
`super_admin`	超级管理员	全系统控制	张总（工号 10001）
`operations_manager`	运营管理层	业务决策 + 审批	李经理（工号 10086）
`leasing_specialist`	租务专员	合同 + 租客日常操作	王专员（工号 20031）
`finance_staff`	财务人员	财务收支 + 核销	赵会计（工号 30012）
`frontline_staff`	前线员工	工单提报 + 只读查询	陈师傅（工号 40005）

默认角色： `operations_manager` （李经理）

三、权限字符串（Phase 1 范围）

完整权限字符串 21 个，按模块分组：

权限字符串	含义	SA	OM	LS	FS	FL
`assets.read`	查看资产	✅	✅	✅	✅	✅
`assets.write`	编辑资产	✅	✅	❌	❌	❌
`contracts.read`	查看合同	✅	✅	✅	✅	✅[1]
`contracts.write`	编辑合同	✅	✅	✅	❌	❌

`deposit.read`	查看押金	✅	✅	✅	✅	❌
`deposit.write`	编辑押金	✅	✅	❌	✅	❌
`finance.read`	查看财务	✅	✅	✅[2]	✅	❌
`finance.write`	编辑财务	✅	❌	❌	✅	❌
`kpi.view`	查看 KPI	✅	✅	✅	✅	✅
`kpi.manage`	管理 KPI	✅	✅	❌	❌	❌
`workorders.read`	查看工单	✅	✅	✅	❌	✅
`workorders.write`	编辑工单	✅	✅	❌	❌	✅
`sublease.read`	查看子租赁	✅	✅	✅	✅	❌
`sublease.write`	编辑子租赁	✅	✅	✅	❌	❌
`alerts.read`	查看预警	✅	✅	✅	✅	❌
`alerts.write`	处理预警	✅	✅	❌	❌	❌
`ops.read`	查看运维	✅	✅	❌	❌	❌
`ops.write`	编辑运维	✅	❌	❌	❌	❌
`org.read`	查看组织	✅	✅	✅	✅	✅
`org.manage`	管理组织	✅	✅	❌	❌	❌
`import.execute`	执行导入	✅	✅	✅[3]	✅[3]	❌

注释:

1. FL 的 `contracts.read` 限制为只读租客基本信息 + 合同摘要，**不可查看财务金额字段**
2. LS 的 `finance.read` 限制为仅查看关联账单，**不可查看全局 NOI 报表**
3. LS 仅可执行租务导入，FS 仅可执行财务导入

四、三层权限控制架构

```
┌──────────────────────────────────────┐
│  Layer 1: 路由守卫 (Page-level)       │ ← 无权限 → 重定向首页
├──────────────────────────────────────┤
│  Layer 2: <Can> 门控 (Feature-level) │ ← 无权限 → 不渲染该区块
├──────────────────────────────────────┤
│  Layer 3: <MaskedField> (Field-level)│ ← 无权限 → 显示 ***
└──────────────────────────────────────┘
```

五、实施步骤

Phase A: Auth 基础设施（新建 4 个文件）

Step 1: 类型与权限常量

- 文件: `frontend/src/app/auth/types.ts`
- 内容:
  - `Role` 联合类型（5 个内部角色）
  - `Permission` 联合类型（21 个权限字符串）
  - `MockUser` 接口（id / name / title / role / employeeNo / permissions）
- 文件: `frontend/src/app/auth/permissions.ts`
- 内容:
  - `ROLE_PERMISSIONS` : `Record<Role, Permission[]>` 严格按 RBAC 矩阵
  - `MOCK_USERS` : 5 个预定义用户
  - `hasPermission(role, permission)` 判定函数
  - `TAB_PERMISSIONS` : Tab 可见性映射
  - `ROUTE_PERMISSIONS` : 路由权限映射

Step 2: React Context

- 文件: `frontend/src/app/auth/AuthContext.tsx`
- 内容:
  - `AuthProvider` 包裹应用
  - `useAuth()` hook 暴露: `user` , `role` , `can(permission)` , `switchRole(role)`
  - `localStorage` 持久化当前角色选择
  - 默认角色: `operations_manager`

Step 3: 门控组件

- 文件: `frontend/src/app/auth/Can.tsx`
- 内容:
  - `<Can permission="xxx">` — 有权限渲染 children，无权限渲染 fallback 或不渲染
  - `<MaskedField permission="xxx" value="123">` — 无权限显示 `***`

Phase B: 导航层集成（修改 3 个文件）

Step 4: 注入 AuthProvider

- 文件: `frontend/src/app/routes.tsx`
- 修改: 在 Layout 外层包裹 `AuthProvider`

Step 5: Tab Bar 过滤

- 文件: `frontend/src/app/components/BottomTabBar.tsx`

- 修改: 根据 `TAB_PERMISSIONS` 过滤不可见 Tab

Tab	所需权限	SA	OM	LS	FS	FL
总览	— (所有人可见)	✅	✅	✅	✅	✅
资产	`assets.read`	✅	✅	✅	✅	✅
合同	`contracts.read`	✅	✅	✅	✅	✅
工单	`workorders.read`	✅	✅	✅	❌	✅
财务	`finance.read`	✅	✅	✅[2]	✅	❌

Step 6: 路由守卫

- 文件: `frontend/src/app/Layout.tsx`
- 修改: 对照 `ROUTE_PERMISSIONS` 表检查当前路径，无权限重定向 `/`

路由模式	所需权限	被阻断角色
`/noi`	`finance.read` （限 SA/OM）	LS, FS, FL
`/wale`	`contracts.read`	—
`/finance/**`	`finance.read`	FL
`/finance/kpi`	`kpi.view`	—
`/work-orders/**`	`workorders.read`	FS
`/subleases`	`sublease.read`	FL
`/contracts/**`	`contracts.read`	—
`/assets/**`	`assets.read`	—

> 注: `/noi` 路由虽然 LS 有 `finance.read` ，但其权限限制为"仅关联账单"，NOI 全局报表不可见，因此特殊阻断。

Phase C: 页面适配（修改 6 个页面）

Step 7: Home.tsx 角色化

区块	所需权限	SA	OM	LS	FS	FL
Header（标题 + 搜索）	—	✅	✅	✅	✅	✅
核心概览卡（出租率 hero）	`assets.read`	✅	✅	✅	✅	✅
核心概览卡（财务条）	`finance.read`	✅	✅	✅[2]	✅	❌
运营预警 AlertRadar	`alerts.read`	✅	✅	✅	✅	❌
常用应用 — 资产登记	`assets.write`	✅	✅	❌	❌	❌
常用应用 — 合同录入	`contracts.write`	✅	✅	✅	❌	❌
常用应用 — 查看账单	`finance.read`	✅	✅	✅[2]	✅	❌
常用应用 — 报修派单	`workorders.write`	✅	✅	❌	❌	✅
常用应用 — 财务总览	`finance.read`	✅	✅	❌	✅	❌
常用应用 — 续租管理	`contracts.write`	✅	✅	✅	❌	❌
常用应用 — 异常预警	`alerts.read`	✅	✅	✅	✅	❌
WALE 摘要	`contracts.read`	✅	✅	✅	✅	✅
待办任务	— (按类型过滤)	全部	全部	合同+子租赁	财务	工单

Step 8: Assets.tsx 角色化

- 所有角色可查看（ `assets.read` 全角色拥有）
- 编辑/导入按钮仅 SA/OM 可见（ `assets.write` ）

Step 9: Contracts.tsx 角色化

- 列表查看: 所有角色（FL 脱敏金额字段）
- 新建合同按钮: SA/OM/LS（ `contracts.write` ）
- 金额字段: FL 显示 `***` （ `<MaskedField>` ）

Step 10: WorkOrders.tsx 角色化

- 列表: SA/OM/LS/FL（FS 无权限，页面不可达）
- 新建工单: SA/OM/FL（ `workorders.write` ）
- 派单/验收: SA/OM（ `workorders.write` + 管理权限）

Step 11: Finance.tsx 角色化

- 整页: SA/OM/FS（FL 无权限，页面不可达）

- LS: 可见但隐藏 NOI 卡片、仅展示关联账单入口
- NOI 入口: 仅 SA/OM
- 账单操作按钮: SA/FS（`finance.write`）

Step 12: Profile.tsx 角色切换

- 顶部显示当前 Mock 用户信息（名称、角色、工号）
- 新增「演示角色切换」区块:
  - 5 个角色按钮，当前角色高亮
  - 标注「演示功能」提示
  - 切换后自动刷新页面权限
- 菜单项按权限过滤:
  - 权限管理: 仅 SA/OM
  - 系统设置: 仅 SA

Phase D: 验证

Step 13: 编译验证

- `pnpm build` 零错误

Step 14: 合规复查

- 逐角色验证 Tab 可见性
- 逐角色验证路由守卫
- 逐角色验证 Home 各区块
- 逐角色验证字段脱敏
- 对照 RBAC_MATRIX.md 逐条检查

六、新建文件清单

文件	类型	说明
`frontend/src/app/auth/types.ts`	新建	类型定义
`frontend/src/app/auth/permissions.ts`	新建	权限常量表 + 工具函数
`frontend/src/app/auth/AuthContext.tsx`	新建	Context Provider + Hook
`frontend/src/app/auth/Can.tsx`	新建	门控组件 + 脱敏组件

七、修改文件清单

文件	修改内容
`routes.tsx`	注入 AuthProvider
`BottomTabBar.tsx`	Tab 按权限过滤
`Layout.tsx`	路由守卫 + 重定向
`Home.tsx`	各区块权限门控
`Assets.tsx`	编辑按钮权限控制
`Contracts.tsx`	新建按钮 + 金额脱敏
`WorkOrders.tsx`	新建/派单按钮权限
`Finance.tsx`	LS 限制 + NOI 门控
`Profile.tsx`	角色切换器 + 信息展示